

GreenLeaf E-Commerce – Vendor Security Contract Clause

To be included in all contracts with Critical and High-risk vendors.

1. **Security Obligations**

The Vendor shall maintain and enforce commercially reasonable security measures, including but not limited to: Multi-Factor Authentication (MFA) for all administrative access, encryption of Customer Data at rest (AES-256) and in transit (TLS 1.2 or higher), and a formal, documented Incident Response Plan that has been tested within the preceding twelve (12) months.

2. **Breach Notification**

The Vendor shall notify GreenLeaf in writing of any confirmed or suspected security incident, data breach, or unauthorized access to Customer Data within **twenty-four (24) hours** of discovery. The notification shall include, to the extent known, the nature of the incident, the affected data, and the corrective actions taken.

3. **Right to Audit**

GreenLeaf, or its designated third-party representative, shall have the right to conduct a security audit of the Vendor's systems, controls, and processes related to the protection of Customer Data. Such audits shall be conducted upon reasonable notice (not less than thirty (30) days) and shall be limited to no more than once per calendar year, unless a security incident has occurred. The cost of such audits shall be borne by GreenLeaf, unless the audit reveals a material non-compliance, in which case the Vendor shall reimburse GreenLeaf for the cost of the audit.